

JPMorgan Chase 2014: GRC Case Study

Model Answers, Tasks 1–9

Girish Nair

MODEL ANSWER MASTER REFERENCE — TASKS 1–9

JPMorgan Chase 2014 Cyber Incident | GRC Case Study

Combined instructor answer key across the full nine-task simulation

1. Purpose

This is the single reference version of what a strong answer looks like at every stage of the simulation, Task 1 through Task 9. Each task's model answer stands on its own and is summarized here in sequence so instructors can grade against one consistent standard, and so capstone presenters can be coached against the intended answer. Multiple good answers are possible for each task; what matters is that the required elements are present and reasoning is supported by the case.

2. The Governance Thread (One Story, Nine Tasks)

One sentence per task shows how the model answers build a single argument: the breach was a governance-completeness failure, not a technology failure.

Task	One-Line Thread
T1	Establish the facts: an unmanaged microsite, no MFA, ~90 servers, 76M/7M records, no financial data confirmed stolen.
T2	Timeline + stakeholders show two missed-intervention points: the MFA/inventory gap and the segmentation gap.
T3	Asset inventory + control scope prove the omission was structural, not a one-off oversight.
T4	Six risk statements convert the gaps into cause-event-impact risks with named owners.
T5	Scoring puts three risks at Critical (R1, R2, R4) and prioritizes MFA exception closure first.
T6	Framework mapping shows Identify/Protect were Partial while Detect/Respond/Recover were Effective.
T7	30-60-90 day plan, exception register, and RACI turn findings into owned, dated actions.
T8	KRIs/KPIs make the same gaps visible on an ongoing basis, not just at audit time.
T9	Tabletop + executive report translate the whole chain into time-bound decisions and one 5-minute briefing.

3. Task-by-Task Model Answer Summary

Task 1 — Case Fact Sheet

150-word case summary, five investigation questions (asset ownership/approval, why excluded from inventory, whether a formal exception existed, segmentation gaps, why detection took 6-8 weeks), and a fact-vs-assumption table. Confirmed: 76M households + 7M small businesses; names/addresses/phones/emails only. Not confirmed: account data, passwords, SSNs, financial data.

Task 2 — Incident Timeline & Stakeholders

7-event timeline (Spring 2014 recon → Nov 2015 DOJ indictments) and an 8-plus stakeholder map spanning CISO, SOC, Asset Owner, IAM, Network Engineering, CRO, Legal, FBI, SEC, and customers. Two missed-intervention points: MFA/CMDB validation before rollout closure, and DMZ isolation with least-privilege access to customer-data environments.

Task 3 — Asset Inventory & Control Scope

Six-asset inventory (microsite shaded as the MFA omission). Control-scope statements: MFA is mandatory for all internet-facing systems based solely on exposure, not criticality; vulnerability management covers all connected assets, enrolled at connection time. Four completeness checks: CMDB-to-discovery reconciliation, control-enrollment cross-check, owner-verification sampling, and a pre-launch security gate.

Task 4 — Risk Statements

ID	Risk Statement (abridged)	Owner	CIA
R1	Incomplete inventory omits internet-facing systems from security programs	CIO / Tech Risk Exec	C,I,A
R2	Untracked MFA exceptions let stolen-credential attackers in	CISO / Head of Identity Security	C,I
R3	Business-managed microsites launch outside security governance	Business Unit Executive	C,I,A
R4	Weak segmentation lets a low-criticality server reach customer systems	Head of Network Security	C,I,A
R5	Monitoring gaps let attackers stay undetected for weeks	SOC Director	C,I
R6	Coverage measured by spend/tools, not actual control reach	CISO / Enterprise Risk Committee	All

Task 5 — Risk Assessment & Prioritization

Score = Likelihood x Impact, 1-4 Low / 5-9 Moderate / 10-16 High / 17-25 Critical.

ID	L	I	Score	Rating
R1 Inventory	4	5	20	Critical
R2 MFA exception	5	5	25	Critical
R3 Portal governance	4	4	16	High
R4 Segmentation	4	5	20	Critical
R5 Delayed detection	4	4	16	High
R6 Coverage assurance	4	4	16	High

Top 3 priorities: (1) R2 MFA exception closure, (2) R4 segmentation/isolation, (3) R1 inventory reconciliation. Two auditor challenges resolved: R1 likelihood held at 4 (not enough evidence of widespread omission yet); R5 impact held at 4 (contact data, not financial data, was exposed).

Task 6 — Framework Mapping

NIST CSF Function	Rating	Rationale (abridged)
Identify	Partial / Gap	Inventory incomplete; microsite and its connectivity path excluded
Protect	Partial / Gap	MFA broadly deployed but not on the breached server; weak segmentation
Detect	Adequate	Detected in 6-8 weeks — better than industry average, still too slow
Respond	Effective	Forensics, law enforcement, containment all executed
Recover	Effective	No financial credentials confirmed stolen; controls restored

Four regulatory mappings cited: FFIEC cyber risk management, FFIEC authentication guidance, GLBA Safeguards Rule, OCC Heightened Standards. Conclusion: the gap was incomplete implementation and insufficient assurance, not absence of a program.

Task 7 — Corrective Action & Exception Management

30-60-90 day plan (disable/enforce MFA and reconcile inventory in 0-30d; register web properties and review firewall rules in 31-60d; institutionalize reconciliation, exception governance, and independent testing in 61-90d). Model exception-register entry (EX-2014-001, MFA gap, 30-day due date, CISO/Business Exec/Tech Risk approvers). RACI matrix across register/assess/approve/implement/validate steps. Residual risk: R-02 reduces from Critical (20) to Moderate (target 8), accepted only with Internal Audit validation and CISO or Board sign-off.

Task 8 — KRIs, KPIs & Monitoring Dashboard

Type	Metric	Target	Owner
KPI	Asset inventory reconciliation completion	100%	Asset Management
KPI	MFA coverage	100% internet-facing	IAM
KRI	Unmanaged assets discovered	0	CIO / Asset Mgmt
KRI	Overdue critical exceptions	0	CISO
KRI	Internet-facing systems without MFA	0	IAM

Escalation rules: any internet-facing system without MFA notifies the CISO immediately; a critical exception past due escalates to executives within 1 business day; two consecutive threshold breaches go to the Technology Risk Committee with a funded plan.

Task 9 — Tabletop & Executive Presentation

Four-inject decision log (unusual login → disable/isolate immediately; lateral connections found → segment and notify CISO within 4 hours; customer-DB access confirmed → engage Legal/Privacy/regulators same day; no financial data confirmed → communicate accurately, no overstatement). Communication matrix across six audiences (Board, Legal/Compliance, SEC, FBI, Employees, Customers) with timing and approval chain for each. One-page executive report and a 5-minute Risk Committee outline: opening, situation/impact, root cause, actions, decisions needed, close. Core lesson: security capability does not create assurance unless governance confirms complete control coverage across every in-scope asset.

4. Consolidated Scoring & Compliance Reference

Risk	Inherent Score	NIST CSF	Key Regulatory Reference
R1 Inventory	20 Critical	IDENTIFY — Partial	FFIEC cyber risk mgmt; OCC Heightened Standards
R2 MFA exception	25 Critical	PROTECT — Partial	FFIEC authentication guidance; GLBA Safeguards
R3 Portal governance	16 High	IDENTIFY / GOVERN	OCC Heightened Standards
R4 Segmentation	20 Critical	PROTECT — Partial	FFIEC Information Security Booklet
R5 Detection latency	16 High	DETECT — Adequate	FFIEC CAT Domain 5
R6 Coverage assurance	16 High	GOVERN	OCC Heightened Standards

5. Using This Reference for Capstone Presentation Prep

Each capstone presenter's section should be checked against the matching task(s) below, since this is the standard the presentation is graded against.

Role	Model-Answer Tasks to Reconcile Against	What "Conformant" Looks Like
S1 — GRC Coordinator	T1, T9 (executive framing)	Opinion is source-grounded; distinguishes fact from assumption
S2 — Asset & Control Analyst	T2, T3, T4 (R1/R3)	Inventory and control-scope checks are traceable to case evidence
S3 — Risk Analyst	T4, T5	Cause-event-impact form; correct L x I scoring against the assigned thresholds
S4 — Compliance & Controls Analyst	T6	Function ratings and regulatory citations match the case's actual gaps
S5 — Incident & Communications Analyst	T2 (stakeholders), T7 (Sec.4), T9	Escalation timing and audience-specific messaging are time-bound
S6 — Internal Auditor	T5 (challenge log), T7 (residual risk)	Challenges are evidenced, not asserted; residual risk has a named acceptance authority

MODEL ANSWER — TASK 1: Understand the Case and Learn the Basic Terms

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 1's required outputs. Multiple good answers are possible — what matters is that the required elements are present and the reasoning is supported by the case.

Case Fact Sheet

Question	Response	Basis
Who was affected?	76M households + 7M small businesses	Verified fact — Incident & Business Impact
What information was accessed?	Names, addresses, phone numbers, email addresses	Verified fact
What was NOT confirmed stolen?	Account data, passwords, SSNs, financial information	Verified fact
Initial entry point?	JPMC Corporate Challenge microsite (unprotected)	Verified fact

Question	Response	Basis
What control was missing?	2FA/MFA — server excluded from the enterprise rollout	Root-cause finding
Why governance, not just tech?	Incomplete asset inventory kept the server out of scope; no documented exception (owner, deadline, compensating control); lateral movement reached ~90 servers	Root-cause finding
Fact vs. assumption?	A fact is stated directly and supported by evidence; an assumption fills a gap the source doesn't confirm and needs further evidence	Definitional

150-Word Summary

June 2014: JPMorgan's Corporate Challenge microsite (a charitable running-event site) was breached using compromised login credentials. The server had not been upgraded to 2FA during JPMorgan's enterprise rollout because it was missing from the asset inventory that drove that project. From that single foothold, attackers moved laterally across roughly 90 servers and reached a customer database. JPMorgan's security team detected the activity in late July, after about 6–8 weeks of dwell time. By August the breach was contained: approximately 76 million households and 7 million small businesses had contact data accessed (names, addresses, phone numbers, emails) — no SSNs, passwords, or financial data were confirmed stolen. Public disclosure followed via an SEC filing in October. Regulatory outcome details remain an open evidence item.

Five Investigation Questions

- Who owned the Corporate Challenge microsite, and who approved its connection to JPMorgan's internal network? — establishes the accountability gap that let an unmanaged asset reach the internal network.
- Why was the server excluded from the asset inventory? — the root cause: this exclusion is why it missed the 2FA rollout entirely.
- Was a formal MFA exception ever recorded, approved and assigned to an owner? — tests whether a real exception process existed or the gap was simply unmanaged.
- What segmentation or firewall gaps let attackers reach the customer database? — identifies whether network design amplified a low-risk asset into a high-impact breach.
- What logs or alerts eventually detected the activity, and why did detection take 6–8 weeks? — assesses whether monitoring tools worked but response was slow, or detection itself was delayed.

MODEL ANSWER — TASK 2: Build the Incident Timeline and Identify Stakeholders

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 2's required outputs. Multiple good answers are possible — what matters is that the required elements are present and the reasoning is supported by the case.

Incident Timeline (7-event minimum)

Date/Period	Event	Category	Why It Matters
Spring 2014	Reconnaissance of internet-facing infrastructure; Corporate Challenge microsite identified	Attack activity	Shows attackers scanned for assets outside standard security coverage
Mid-June 2014	Initial access via compromised credentials on the MFA-excluded server	Attack activity	Root-cause control gap: one unmanaged asset became the entry point
Jun-Jul 2014	Lateral movement to ~90 servers; contact data for 76M/7M accessed	Attack activity	Reflects weak segmentation between the DMZ and customer-data zones
Late July 2014	Security team detects and confirms unauthorized access	Detection	~6–8 weeks dwell time — the key monitoring-effectiveness metric
August 2014	Access revoked, systems remediated (incl. accelerated MFA); FBI and regulators notified	Response	Containment speed/completeness determines residual attacker access
Early Oct 2014	SEC Form 8-K filed; affected customers notified	Disclosure	Triggered once scope and materiality were confirmed with Legal
Nov 2015	DOJ unseals indictments against those responsible	Legal follow-up	Closes the incident lifecycle; external validation of root cause

Stakeholder Map (8-minimum, internal + external)

Stakeholder	Role / Decision Authority	Information Needed	Timing
CISO (internal)	Approves/denies control exceptions; authorizes IR strategy	Exception register, risk dashboard, incident status	Immediate at detection
SOC (internal)	Escalates alerts; triggers IR playbook	SIEM alerts, auth logs, anomaly data	Continuous; immediate
Asset Owner / Infra (internal)	Approves onboarding; certifies inventory completeness	CMDB, exception requests, patch status	Ongoing pre-incident; post-incident remediation
IAM (internal)	Approves/rejects MFA coverage exceptions	MFA coverage reports, exception log	Ongoing; validated during remediation
Network Engineering (internal)	Approves segmentation/access-control design	Topology maps, firewall rules	Pre-incident design; active in containment
CRO / Enterprise Risk (internal)	Accepts, mitigates, or escalates residual risk	Risk register, KRIs, control-effectiveness data	Escalation within 24–48 hrs
Legal / General Counsel (internal)	Determines disclosure timing; authorizes law-enforcement contact	Breach scope, notification-law	Immediate upon confirmed breach

Stakeholder	Role / Decision Authority	Information Needed	Timing
		requirements	
FBI / Law Enforcement (external)	Independent authority over investigation	IOCs, forensic evidence	Promptly after detection
SEC / Regulators (external)	Independent authority to require disclosure	8-K content, incident scope	Per statutory disclosure deadline
Affected Customers (external)	Informational recipient of notice	What data was affected; protective steps	At public disclosure

Two Missed-Intervention Points

- MFA/asset-inventory gap: Infrastructure & IAM should have validated 100% MFA coverage against a continuously reconciled CMDB before closing the rollout — likely blocks initial access.
- Network segmentation: Network Engineering should have enforced DMZ isolation and least-privilege access to customer-data environments — delays or blocks attacker reach to customer data.

Additional Information Requested

Exact reconnaissance date range; the forensic report identifying the specific detection trigger; any MFA exception record covering the affected server; the full SEC 8-K text; DOJ indictment records confirming attribution.

MODEL ANSWER — TASK 3: Create an Asset Inventory and Define Control Scope

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 3's required outputs. Multiple good answers are possible — what matters is that the required elements are present and the reasoning is supported by the case.

Asset Inventory (6-minimum; shaded item = MFA omission)

Asset	Business Owner	Technical Owner	Data Handled	Internet?	Applicable Controls
Corporate Challenge Microsite	Corporate/Community Affairs	IT Web Services	Event registration info (low sensitivity)	Yes	MFA: MISSING (root cause). Patch status unconfirmed.
Customer Online/Mobile Banking	Retail Banking	Digital Channels IT	Customer PII, account/transaction data	Yes	MFA, encryption, continuous monitoring
Customer Contact	Consumer & Community Banking	Database/Infra Team	Names, addresses, phone, email	No	Access control, encryption at

Asset	Business Owner	Technical Owner	Data Handled	Internet?	Applicable Controls
Database			(~76M/7M)		rest, segmentation
Active Directory / IAM System	Information Security	IAM Team	Credentials, access entitlements	No	Privileged access mgmt, admin MFA, logging
Enterprise Network / DMZ	IT Infrastructure	Network Engineering	N/A (infrastructure)	Partial (DMZ)	Segmentation, firewall rules, IDS/IPS
SIEM / Security Monitoring	CISO / Info Security	Security Operations Center	Logs, security events	No	Log retention, correlation rules, alerting

Control-Scope Statement — MFA

All internet-facing systems are in scope for mandatory multi-factor authentication, without exception, based solely on internet exposure — not business criticality, asset type, or sponsoring department. Any exception requires documented, time-bound risk acceptance approved by Information Security leadership and tracked to an expiration date.

Control-Scope Statement — Vulnerability Management

All assets connected to the corporate network — internet-facing or internal — are in scope for recurring vulnerability scanning and timely patching, prioritized by exploitability and network exposure. Newly registered assets are enrolled at the time of network connection, not at the next scheduled review cycle.

Four Inventory Completeness Checks

- CMDB-to-discovery reconciliation: run automated network/DNS discovery monthly and reconcile against the CMDB; every discrepancy gets a named owner and risk decision within 5 business days.
- Control-enrollment cross-check: cross-reference the MFA enrollment list and vulnerability-scan inventory against the full CMDB — any asset in one list but not another is an open exception.
- Owner-verification sampling: periodically contact a sample of listed owners and confirm they can identify their asset — catches stale or incorrect ownership records.
- Pre-launch gate: require a security checklist (registration, MFA, vuln-scan enrollment) before any new internet-facing asset goes live — prevents a repeat of the Corporate Challenge gap at the source.

MODEL ANSWER — TASK 4: Identify Risks and Write Clear Risk Statements

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 4's required outputs. Multiple good answers are possible — what matters is that the required elements are present and the reasoning is supported by the case.

Risk Register — Identification Stage (formula: Because of [cause], there is a possibility that [event], resulting in [impact])

ID	Risk Statement	Control Gap	Risk Owner	CIA
R1	Because the asset inventory is incomplete, internet-facing systems may be omitted from mandatory security programs, resulting in unauthorized access, data exposure, regulatory criticism and reputational harm.	Asset inventory & reconciliation	CIO / Technology Risk Executive	C, I, A
R2	Because MFA exceptions are not formally tracked and escalated, attackers using stolen passwords may access corporate systems, resulting in account compromise and unauthorized network entry.	MFA coverage & exception management	CISO / Head of Identity Security	C, I
R3	Because business-managed microsites are commissioned outside standard security governance, vulnerable internet-facing systems may be launched or retained, resulting in an expanded attack surface and control noncompliance.	Secure onboarding & web-property registration	Business Unit Executive	C, I, A
R4	Because network segmentation and cross-zone access controls are insufficient, an attacker compromising a low-criticality web server may move to customer systems, resulting in large-scale data exposure and operational disruption.	Network segmentation & firewall governance	Head of Network Security	C, I, A
R5	Because monitoring rules do not identify unusual authentication, lateral movement and bulk data access quickly enough, attackers may remain undetected for weeks, resulting in greater data loss and investigation cost.	Security logging, SIEM coverage & alerting	SOC Director	C, I
R6	Because security program effectiveness is measured mainly by tools and spending rather than control coverage, management may receive false assurance, resulting in unaddressed exceptions and repeated control failures.	Coverage assurance & governance reporting	CISO / Enterprise Risk Committee	All

Question Answers

- Is “no MFA” a risk or a control gap? It's a control gap. The risk is what could happen because the control is missing.
- What business impacts follow from an incomplete asset inventory? Missed patching, missed MFA, missed monitoring, unknown data exposure, compliance gaps, and delayed incident response.
- Why should business owners hold cybersecurity risk ownership? The business owner creates or uses the service, understands the business need and impact, and must accept or fund risk decisions — the executive owns the business risk while technical teams operate the controls.

MODEL ANSWER — TASK 5: Assess and Prioritize the Risks

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 5's required outputs. Multiple good answers are possible — what matters is that the required elements are present and the reasoning is supported by the case.

Risk Register (Score = Likelihood × Impact; 1–4 Low, 5–9 Moderate, 10–16 High, 17–25 Critical)

ID	Risk	L	I	Score	Rating	Rationale
R1	Incomplete asset inventory	4	5	20	Critical	The missed asset demonstrates likely recurrence without systemic correction.
R2	Untracked MFA exception	5	5	25	Critical	The event occurred and enabled initial access; customer exposure was severe.
R3	Business-managed portal governance	4	4	16	High	Similar portals may exist and can create internet-facing gaps.
R4	Insufficient network segmentation	4	5	20	Critical	Attackers reached ~90 servers and a large customer database.
R5	Delayed detection	4	4	16	High	Six-to-eight week dwell time allowed broad access.
R6	Coverage assurance weakness	4	4	16	High	Management can receive false assurance across multiple control programs.

Top-Three Priorities

- Priority 1 — R2, untracked MFA exception: close all externally accessible MFA exceptions and apply compensating controls immediately.
- Priority 2 — R4, network segmentation: isolate internet-facing systems and remove unnecessary connectivity to customer-data zones.
- Priority 3 — R1, inventory completeness: establish reconciliation so other unknown assets are identified before they repeat this pattern.

Internal Auditor Challenges (2 minimum)

- Challenge: R1 likelihood could be 5 because one missed asset proves the process failed. Decision: kept at 4 — the number of other unknown assets is not established; raise to 5 if discovery finds widespread omissions.
- Challenge: R5 impact could be 5 given 83 million affected customer/business relationships. Decision: kept at 4 — contact data, not financial credentials, was accessed; raise to 5 if financial data or fraud is confirmed.

Question Answers

- Why are R2/R4 high or critical? Both directly enabled access and expansion of the breach and involved highly sensitive customer systems.
- Can two risks share a score but differ in urgency? Yes — active exploitation, regulatory deadlines, available quick fixes, and concentration risk can all change urgency independent of score.
- What evidence would change a score? New incidents, control testing results, discovery findings, data classification, financial-loss estimates, and threat intelligence.

MODEL ANSWER — TASK 6: Map the Gaps to GRC Frameworks and Requirements

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 6's required outputs. Multiple good answers are possible — what matters is that the required elements are present and the reasoning is supported by the case.

NIST CSF Function-Level Assessment

Function	Rating	Rationale
Identify	Partial / Gap	The asset inventory was incomplete and did not include the microsite or its connectivity path.
Protect	Partial / Gap	MFA was broadly deployed but not applied to the breached server; segmentation and compensating controls were inadequate.
Detect	Adequate, needs improvement	Internal monitoring detected the breach in six to eight weeks — better than the historical industry average, but too late to prevent broad access.
Respond	Effective	The bank investigated, engaged forensics and law enforcement, contained the breach, and closed the vulnerability.
Recover	Effective	No financial credentials were confirmed stolen; the bank restored control and increased security investment.

Regulatory Mapping (4 requirements)

Requirement	Case Implication
FFIEC cyber risk management	Requires comprehensive asset and risk management; the omitted internet-facing server shows incomplete scope.
FFIEC authentication guidance	Supports MFA for high-risk and remote access; a single-factor internet-facing server was inconsistent with the expected control.
GLBA Safeguards Rule	Requires a comprehensive information-security program covering customer information systems; the access path to customer records showed a coverage gap.
OCC Heightened Standards	Large banks are expected to maintain strong front-line risk governance; the missed system and unmanaged exception indicate weak execution.

Evidence an Auditor Would Request

- Asset inventory and asset-owner certification records; network discovery and inventory-reconciliation reports.
- MFA enrollment report and exception register; vulnerability scan and patch-compliance reports.
- Firewall diagrams, rules and approval records; SIEM log-source coverage and alert-use-case documentation.
- Incident tickets, forensic report and containment records; risk committee minutes and executive approvals; SEC filing and regulatory communication records.

Compliance Conclusion

The organization had mature capabilities and policies, but evidence shows material gaps in control coverage and exception governance. Identify and Protect were not fully effective because the inventory, MFA scope and segmentation controls did not cover every relevant system. Detect, Respond and Recover functioned more effectively, limiting the incident after discovery. The compliance concern is therefore not absence of a program, but incomplete implementation and insufficient assurance that mandatory controls applied to all in-scope assets.

MODEL ANSWER — TASK 7: Design the Corrective Action and Exception Management Plan

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 7's required outputs. Multiple good answers are possible — what matters is that the required elements are present and the reasoning is supported by the case.

Model 30-60-90 Day Corrective-Action Plan

Window	Action	Owner	Evidence
0–30d	Disable/restrict the compromised access path; enforce MFA on the microsite; reset credentials; isolate the server; review all internet-facing MFA exceptions.	CISO, IAM, Network Security	MFA coverage report, firewall change, incident ticket, exception list
0–30d	Run discovery of all internet-facing assets and reconcile against the asset inventory.	Infrastructure Asset Mgmt	Discovery report, unmatched-asset log
31–60d	Register every web property; assign a business and a technical owner; classify data and connectivity.	Business Technology Governance	Approved inventory, owner certifications
31–60d	Review cross-zone firewall rules; remove unjustified paths from internet-facing systems to customer-data zones.	Network Security	Approved rule review, updated diagram
31–60d	Implement SIEM alerts for unusual authentication, lateral movement, and bulk data access.	SOC Engineering	Use-case test results, alert tickets
61–90d	Establish monthly inventory reconciliation and quarterly business certification.	CIO / GRC	Operating procedure, dashboard, first completed review
61–90d	Implement formal exception governance with aging thresholds and executive escalation.	CISO / Technology Risk	Exception policy, register, committee minutes
61–90d	Independent test of MFA, asset coverage, and segmentation actions — by a function separate from the implementer.	Internal Audit / 2nd-Line Risk	Validation report, closure recommendation

Model Exception-Register Entry

Field	Response
ID	EX-2014-001
Control / Asset	MFA required for internet-facing corporate systems — Corporate Challenge microsite server
Reason	Legacy application not integrated with the enterprise MFA rollout
Owner	Corporate Events Technology Owner
Risk	A stolen password could permit unauthorized entry and lateral movement
Compensating Controls	Restrict access by source IP; monitor every login; disable unnecessary accounts; isolate the network segment; daily log review
Due Date / Status	Within 30 days — Open, Critical
Approvers	Business Executive, CISO, and Technology Risk
Escalation	Immediate CISO notification; executive approval required if not closed by the due date
Closure Evidence	MFA test result, updated inventory entry, access review, and independent validation sign-off

Model RACI Matrix

Activity	Responsible	Accountable	Consulted	Informed
Register new asset	Business owner	Business executive	Asset Mgmt, Security	GRC, Internal Audit
Assess required controls	Security Architecture	CISO delegate	Business owner, Privacy	GRC
Approve exception	GRC (prepares)	CISO / Business exec.	Legal, Risk owner	Internal Audit
Implement remediation	Technical control owner	Risk owner	GRC, Vendor	Executive management
Validate closure	2nd-Line Risk / Internal Audit	Chief Risk / Audit authority	Control owner	Risk Committee

Residual-Risk Statement

After MFA enforcement, segmentation, inventory reconciliation, and monitoring improvements, the unmanaged-exception risk (R-02) may reduce from Critical (inherent 20) to Moderate (target residual 8: likelihood 2, impact 4). The business risk owner may accept the remaining exposure only after independent validation by Internal Audit or second-line Risk, and documented approval by the CISO or, where the residual sits outside the stated tolerance threshold, the Board Risk Committee on a time-limited, non-renewable acceptance.

MODEL ANSWER — TASK 8: Create KRIs, KPIs and an Ongoing Monitoring Dashboard

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 8's required outputs. Multiple good answers are possible — what matters is that the required elements are present and the reasoning is supported by the case.

Model Metric Catalog

Type	Metric	Calculation	Target	Threshold	Owner	Frequency
KPI	Asset inventory reconciliation completion	% of monthly reconciliations completed by due date	100%	<100%	Asset Management	Monthly
KPI	MFA coverage	% of in-scope systems/users enrolled in MFA	100% internet-facing; ≥99% overall	<100% internet-facing	IAM	Weekly
KPI	Internet-facing security review	% of registered web properties with a current annual review	100%	<95%	Security Architecture	Monthly
KPI	Corrective actions closed on time	% of actions closed by agreed date	≥95%	<90%	GRC	Monthly
KRI	Unmanaged assets	Count of discovered assets not in the managed inventory	0	>0	CIO / Asset Management	Weekly
KRI	Overdue critical exceptions	Count of critical exceptions past due	0	>0	CISO	Daily / Weekly
KRI	Internet-facing systems without MFA	Count of internet-facing systems not protected by MFA	0	>0	IAM	Daily
KRI	Unapproved cross-zone firewall rules	Count of rules without current owner/business justification	0	>0	Network Security	Monthly

Model One-Page Dashboard

Measure	Status	Result	Action
Asset inventory coverage	Amber	Discovery found three unregistered assets; owners assigned.	Track to closure at next monthly cycle.

Measure	Status	Result	Action
Internet-facing MFA coverage	Red	One critical exception remains open.	Restrict access until compensating control approved; notify CISO.
Critical exceptions past due	Red	One item exceeded its target date.	Executive escalation within 1 business day; track weekly.
Firewall review completion	Amber	92% reviewed; target is 100%.	Assign owner and date; review at monthly control forum.
High-severity detection time	Green	Median 2.5 hours after new alert rules.	Continue monitoring; report trend.
Corrective actions on time	Green	96% closed by due date.	Continue monitoring; report trend.

Escalation Rules

- Internet-facing system without MFA: notify CISO and risk owner immediately; restrict access until an approved compensating control is in place.
- Critical exception past due: executive escalation within one business day, with weekly tracking until closure.
- Unmanaged asset discovered: classify, assign an owner, and place it into the applicable control programs within two business days.
- Repeated threshold breach for two consecutive reporting periods: present to the Technology Risk Committee with a funded corrective plan.

MODEL ANSWER — TASK 9: Conduct the Incident Tabletop and Present to Executives

JPMorgan Chase 2014 GRC Case Study This model answer shows one strong way to meet Task 9's required outputs. Multiple good answers are possible — what matters is that decisions are time-bound, escalation is clear, and communication reflects only verified facts.

Tabletop Decision Log

Inject	Decision	Owner	Deadline	Rationale	Evidence
1 — SOC confirms unusual login to an internet-facing microsite using a valid employee account.	Disable/reset the account; isolate the server; preserve logs; declare a high-severity incident; assign an incident commander.	SOC / Incident Commander	Immediate (within the hour)	Contain confirmed unauthorized access before scope is known, and preserve evidence before it degrades.	Account-disable ticket, isolation confirmation, incident declaration record, SOC log extract.
2 — Forensics finds	Block unnecessary cross-zone paths;	Network Security / IAM; CISO	Within 4 hours of the	Lateral movement	Firewall change record,

Inject	Decision	Owner	Deadline	Rationale	Evidence
connections from the microsite to multiple internal servers.	segment affected systems; review privileged credentials; notify CISO, Legal, and executive leadership.	notified	finding	signals enterprise-scale exposure; further reach must be limited before data scope is known.	segmentation confirmation, privileged-access review log, executive notification timestamp.
3 — Evidence shows access to a customer contact database and ~90 servers.	Engage Privacy, regulators, and law enforcement; assess data scope and materiality; preserve evidence; determine customer-protection actions.	Legal / Privacy / Incident Commander	Same day — materiality assessment opened	Scale of access likely triggers regulatory notification and disclosure clocks that must be assessed before any external statement.	Data-scoping report, regulator/FBI engagement log, decision-log entry, preserved forensic image.
4 — No account numbers, passwords, or SSNs are confirmed stolen.	Communicate accurately: state confirmed data, unknowns, actions taken, and ongoing monitoring; do not claim zero risk.	Corporate Communications / Legal; approved by CISO / executives	Before any public or customer statement is released	Overstating certainty is a reputational and legal liability if new facts emerge; understating is a disclosure risk.	Approved message draft, legal sign-off, distribution log.

Communication Matrix

Audience	Information	Timing	Owner	Approval
Executive leadership / Board	Scope, customer impact, business disruption, regulatory exposure, decisions and resources needed.	Every 2–4 hours initially	CISO / Incident Commander	Not required for internal briefing; Board informed, not asked to approve.
Legal / Compliance / Privacy	Data involved, jurisdictions, materiality, notification deadlines, evidence status.	Continuous during scoping	Incident Commander	General Counsel
Regulators / SEC	Material verified facts, timing, impact, remediation.	Per applicable regulatory deadline	Legal / Corporate Secretary	Disclosure Committee / General Counsel

Audience	Information	Timing	Owner	Approval
FBI / Law enforcement	Indicators, evidence, suspected criminal activity.	Promptly after confirmation	Legal / CISO	General Counsel / CISO
Employees	Required credential resets, phishing awareness, operational instructions.	As actions are approved	Internal Communications	CISO
Customers	Confirmed data affected, protective steps, contact channels.	After facts and obligations are validated	Corporate Communications / Legal	General Counsel, Corporate Communications, CEO sign-off

One-Page Executive Report

Section	Content
Situation	Attackers gained access through an internet-facing Corporate Challenge server omitted from the enterprise MFA upgrade, and used that foothold to reach approximately 90 servers.
Impact	Names, addresses, phone numbers, and email addresses for 76 million households and 7 million small businesses were accessed. No financial account data, passwords, or Social Security numbers were confirmed stolen.
Root Cause	Incomplete asset inventory, ineffective control-exception management, and inadequate segmentation between a low-criticality web property and internal customer systems.
Actions Taken	Containment, credential resets, forensic investigation, law-enforcement coordination, vulnerability closure, data scoping, and executive/regulatory communication.
Decisions Needed	Approve enterprise internet-facing asset review, mandatory MFA exception closure, segmentation remediation, formal exception governance, and independent assurance testing.
Lesson	Security capability does not create assurance unless governance confirms complete control coverage across every in-scope asset.

Five-Minute Risk Committee Presentation — Outline

- Opening (30 sec): One sentence framing — what happened, and that it is contained. Lead with control, not alarm.
- Situation and impact (90 sec): Entry point, what was accessed, what was not confirmed stolen, and current containment status.
- Root cause (60 sec): Frame as governance completeness — inventory, exception management, and segmentation — not a technology failure.
- Actions taken and in progress (60 sec): Containment steps completed; forensic, legal, and regulatory engagement underway.

- Decisions needed from the Committee (60 sec): Name each approval explicitly — asset review scope, exception-closure mandate, segmentation funding, disclosure timing.
- Close (10–15 sec): Confirm next update cadence and who owns the next decision point.

Question Answers

Question	Model Answer
When should operations be interrupted to contain risk?	When continued operation materially increases data loss, attacker access, safety risk, or regulatory exposure — use the least disruptive containment that is still effective.
What facts must be verified before public communication?	Affected systems, data categories, population size, timeline, containment status, any known fraud, applicable legal obligations, and what remains uncertain.
What decisions require executive or Risk Committee approval?	Major shutdowns, public disclosure, material risk acceptance, funding, vendor or service termination, and overdue critical exceptions.
What is the single most important governance lesson?	Governance completeness and exception management are what make security controls actually apply everywhere they are required — capability without coverage is not assurance.